

NorthWind Analytics, Inc.

Vendor Security Questionnaire — Completed Response

SYNTHETIC DOCUMENT — generated for demonstration purposes. All entity names, figures, dates and findings are invented. This document describes no real company.

Completed 22 March 2026 by the NorthWind Analytics security team in response to the Customer's standard assessment. Responses reflect the state of the environment as of the completion date.

Q1. Do you enforce multi-factor authentication for all personnel?

MFA is enforced organisation-wide for all personnel accessing production systems. Enforcement is applied at the identity provider level and cannot be bypassed by individual users.

Vulnerability scans are performed on a continuous basis against internet-facing assets, and identified findings are triaged according to a documented severity matrix.

Production data is encrypted at rest using AES-256 and in transit using TLS 1.2 or higher. Key material is managed through a dedicated key management service with rotation performed annually.

Q2. Where is customer data processed and stored?

Customer data is processed in the us-east-1 and us-west-2 regions. An EU region is on the roadmap; customers with EU residency requirements should discuss current status with their account team, as arrangements are not yet finalised.

Security awareness training is delivered to all personnel upon hire and annually thereafter, with completion tracked and reported to management.

Incident response procedures are documented, assigned to named owners, and exercised through tabletop simulation at least annually.

Q3. Do you hold a current SOC 2 Type II report?

A SOC 2 Type II report covering Security and Confidentiality is available under NDA. The Availability criterion is not currently in scope for our report.

Vendor risk assessments are performed prior to onboarding any subprocessor with access to customer data, and are refreshed on a defined cadence thereafter.

The organisation maintains a documented information security policy that is reviewed and approved by management at least annually and communicated to all personnel and relevant external parties.

Q4. Describe your encryption practices.

Data is encrypted at rest with AES-256 and in transit with TLS 1.3. Keys are managed through a managed KMS with annual rotation.

Changes to production systems follow a documented change management process requiring peer review, automated testing and documented approval prior to deployment.

Vulnerability scans are performed on a continuous basis against internet-facing assets, and identified findings are triaged according to a documented severity matrix.

Q5. How do you manage subprocessors?

A subprocessor register is maintained and published. Customers receive thirty days' notice of additions or replacements and may object on data protection grounds.

Backup procedures are executed daily with restoration testing performed on a quarterly basis. Backup media is encrypted and stored in a geographically separate facility.

Security awareness training is delivered to all personnel upon hire and annually thereafter, with completion tracked and reported to management.

Q6. What is your incident notification commitment?

We commit to notifying affected customers within seventy-two hours of confirming a personal data breach affecting their data.

Monitoring and alerting is configured across production infrastructure with alerts routed to an on-call rotation staffed twenty-four hours per day.

Vendor risk assessments are performed prior to onboarding any subprocessor with access to customer data, and are refreshed on a defined cadence thereafter.

Q7. Do you perform penetration testing?

An independent penetration test is commissioned annually. A summary letter is available under NDA; the full report is not distributed externally.

Logical access to production systems is granted on the basis of least privilege and is reviewed quarterly by system owners. Access is revoked within one business day of termination.

Changes to production systems follow a documented change management process requiring peer review, automated testing and documented approval prior to deployment.

Q8. How is access to production data controlled?

Access follows least privilege, requires named approval, is time-bound for elevated roles, and is reviewed quarterly.

Production data is encrypted at rest using AES-256 and in transit using TLS 1.2 or higher. Key material is managed through a dedicated key management service with rotation performed annually.

Backup procedures are executed daily with restoration testing performed on a quarterly basis. Backup media is encrypted and stored in a geographically separate facility.

Q9. Do you have a documented business continuity plan?

A business continuity plan is documented and exercised annually. The most recent exercise was conducted in November 2026.

Incident response procedures are documented, assigned to named owners, and exercised through tabletop simulation at least annually.

Monitoring and alerting is configured across production infrastructure with alerts routed to an on-call rotation staffed twenty-four hours per day.

Q10. What is your data retention and deletion policy?

Customer data is retained for the contracted period. On termination, data is deleted within thirty days unless a longer period is required by law.

The organisation maintains a documented information security policy that is reviewed and approved by management at least annually and communicated to all personnel and relevant external parties.

Logical access to production systems is granted on the basis of least privilege and is reviewed quarterly by system owners. Access is revoked within one business day of termination.

Q11. Do you use customer data for model training?

No. Customer data is not used to train shared models. Any customer-specific model artefacts remain isolated to that customer's tenant.

Vulnerability scans are performed on a continuous basis against internet-facing assets, and identified findings are triaged according to a documented severity matrix.

Production data is encrypted at rest using AES-256 and in transit using TLS 1.2 or higher. Key material is managed through a dedicated key management service with rotation performed annually.

Q12. Describe your logging and monitoring coverage.

Production infrastructure is monitored continuously with alerts routed to a twenty-four hour on-call rotation. Audit logs are retained for eighteen months.

Security awareness training is delivered to all personnel upon hire and annually thereafter, with completion tracked and reported to management.

Incident response procedures are documented, assigned to named owners, and exercised through tabletop simulation at least annually.